Risk Register: RAG-Diary

> The project risk register, scored by likelihood and impact, with mitigation and an owner for each risk, so the team can watch and act before a risk becomes a problem.

> Thai version: RISK-REGISTER.md

1. Document control

Item	Detail
Document	Risk Register
Version	1.1
Prepared	15 October 2026
Author	Business Analyst / System Analyst (project owner)
Status	Reviewed, round 1 (25 October 2026); R-12 and R-13 added 14 November 2026
Related documents	ADR, DFD-PRIVACY, SRS, NFR-SPEC

2. Purpose and scope

This document answers one question: what could trip the project up, and how will we handle it? It collects technical, security and privacy, cost, delivery and product risks.

Scope: risks that have not yet materialised, with their assessment and mitigation. Out of scope: problems that already happened (those are in CHANGE-REQUEST-LOG).

3. How risks are scored

Each risk scores likelihood (1-5) multiplied by impact (1-5), then falls into a band.

Score range	Level	Meaning
1-4	Low	Watch at the regular review
5-9	Medium	Have a mitigation plan and track it
10-15	High	Needs a clear mitigation plan and an owner
16-25	Critical	Act now, or reduce the risk before proceeding

4. Risk register

ID	Type	Risk	Likelihood	Impact	Score	Level	Mitigation	Owner	Status
R-01	Security	The token is kept in localStorage and can be stolen by a script	4	5	20	Critical	Move to httpOnly cookies and shorten the token lifetime	Dev	Reduced (httpOnly cookies behind a same-origin proxy, ADR-10)
R-04	Privacy	Personal data is processed externally without clear consent	4	5	20	Critical	Inform and ask for consent (consent gate live), minimise the data, put a processor agreement in place	DPO	Reducing
R-02	Security, cost	No rate limit, so usage and cost can run away	4	4	16	Critical	Per-user rate limiting, cost ceiling alerts	Dev, Ops	Closed (enabled 12 Nov 2026; the counter is per route since 14 Nov 2026 and the 429 was verified)
R-10	Delivery	A single maintainer (low bus factor)	4	4	16	Critical	This document set and a knowledge handover	PO	Reducing
R-03	Security	The summary endpoint accepted	3	4	12	High	Define the schema and validate before use	Dev	Closed (fixed)

ID	Type	Risk	Likelihood	Impact	Score	Level	Mitigation	Owner	Status
		unvalidated input							
R-05	Product	Dependence on a single AI provider, risking an outage or a price change	3	4	12	High	Build an adapter that can switch providers, and keep a fallback	Dev	Open
R-07	Product	Poor retrieval quality, so users stop trusting the answers	3	4	12	High	Tune the threshold and collect feedback to assess it	PO, Dev	Reducing (threshold lowered to 0.6; feedback not yet collected)
R-06	Cost	Embedding and image cost grows with users	4	3	12	High	Set quotas, use caching, monitor usage	Ops	Open
R-09	Delivery	No automated tests or CI, so regressions slip through	4	3	12	High	Add a minimum test suite and CI	QA, Dev	Reduced (22 unit tests and GitHub Actions)
R-08	Security	The endpoint returned every column, including embedding and user_id	3	3	9	Medium	Return only the columns the screen needs	Dev	Closed (fixed)
R-11	Technical	Vector search slows down as data grows	2	4	8	Medium	Load tested at 5,000 entries (p95 0.41 s in the	Dev	Reduced

ID	Type	Risk	Likelihood	Impact	Score	Level	Mitigation	Owner	Status
							database); tune HNSW further only when data grows past that		
R-12	Technical	The system is unstable under high concurrency (HTTP 500 at 20 users)	3	4	12	High	Check the connection pool limit, try retries, and measure again at 10, 20 and 30 users before acceptance	Dev	Open
R-13	Security	Test data carrying a password was committed as evidence	2	3	6	Medium	Filter credentials before the file is written, delete the test accounts, and keep real passwords out of committed files	Dev	Closed (14 Nov 2026)

5. Heat map (likelihood x impact)

Impact \ Likelihood	1	2	3	4	5
5				R-01, R-04	
4			R-03, R-05, R-07, R-12	R-02, R-10	
3		R-13	R-08	R-06, R-09	
2		R-11			

Impact \ Likelihood	1	2	3	4	5
1					

6. Risks that need extra attention

ID	Why it needs watching	Early warning sign
R-01	High impact, and it gets harder to fix later	A script vulnerability or a security report
R-04	It touches the personal data requirements directly	Real user data used in testing without consent
R-02	It arrives fast and affects both security and cost	An abnormal daily AI bill
R-10	It threatens continuity when the maintainer is unavailable	Work stalls with no one to pick it up

7. Review cycle

Review the register every two weeks, or whenever a new risk scores High or above.

8. References

Document	Relationship
ADR	The origin of R-01 and R-05
DFD-PRIVACY	The origin of R-04
NFR-SPEC	The quality these risks threaten
CHANGE-REQUEST-LOG	Where a risk is recorded once it becomes a real problem